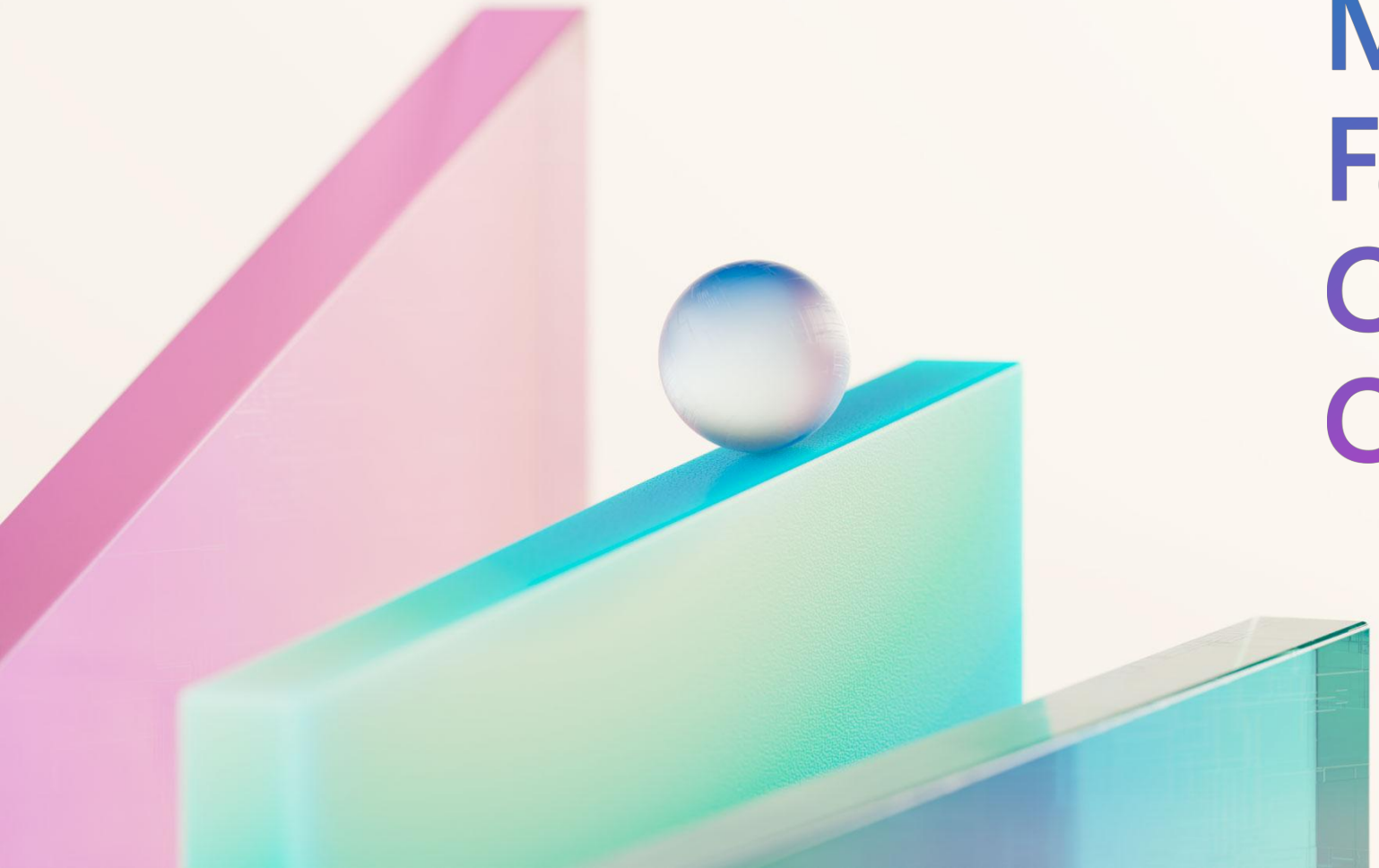
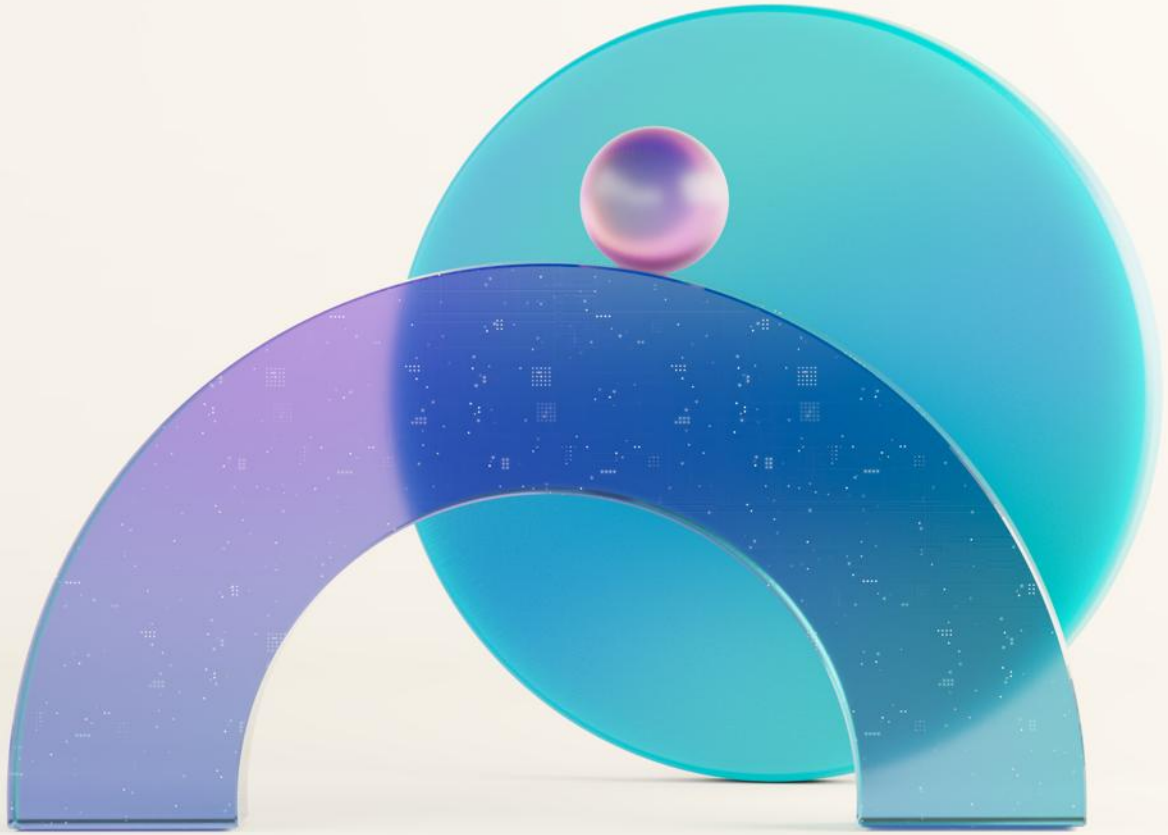
Microsoft



Microsoft Fabric Community Conference

Microsoft

Microsoft Fabric
Community Conference



Fabric Platform Security Best Practices

Examination of real compromises and lessons to be learned

Who Are We?

Paddy Osborne – GM of Security and Privacy for Fabric

Elena Scilletta – Principal Security PM



What are you protecting?

Understanding what assets you have that attackers are after is essential to understanding where to apply additional security controls

- **Sensitive Business Data**

  This includes proprietary information, trade secrets, financial records, and other critical business data that could be used for competitive advantage or sold on the black market

- **Personal User Data**

  Attackers often seek personal information such as names, addresses, social security numbers, and payment details. This data can be used for identity theft, financial fraud, or sold to other malicious actors

- **Compute Resources**

  In some cases, attackers may be interested in fraudulently using your resources or users. They might use these resources for activities like cryptocurrency mining or launching further attacks



Security Considerations

Most organizations are a mix of security conscious engineers and business users with limited technical ability or security training. You can't rely on all your users being savvy to every attack vector.





Even the most secure organizations have multiple supply-chain dependencies. Defense in depth is important.

Insider threat is a real concern but must be balanced with usability and business functions.



We will examine real world compromises to understand the why, where, how, and when, then apply these learnings to best practices that could have prevented them.

Thinking Like an Attacker

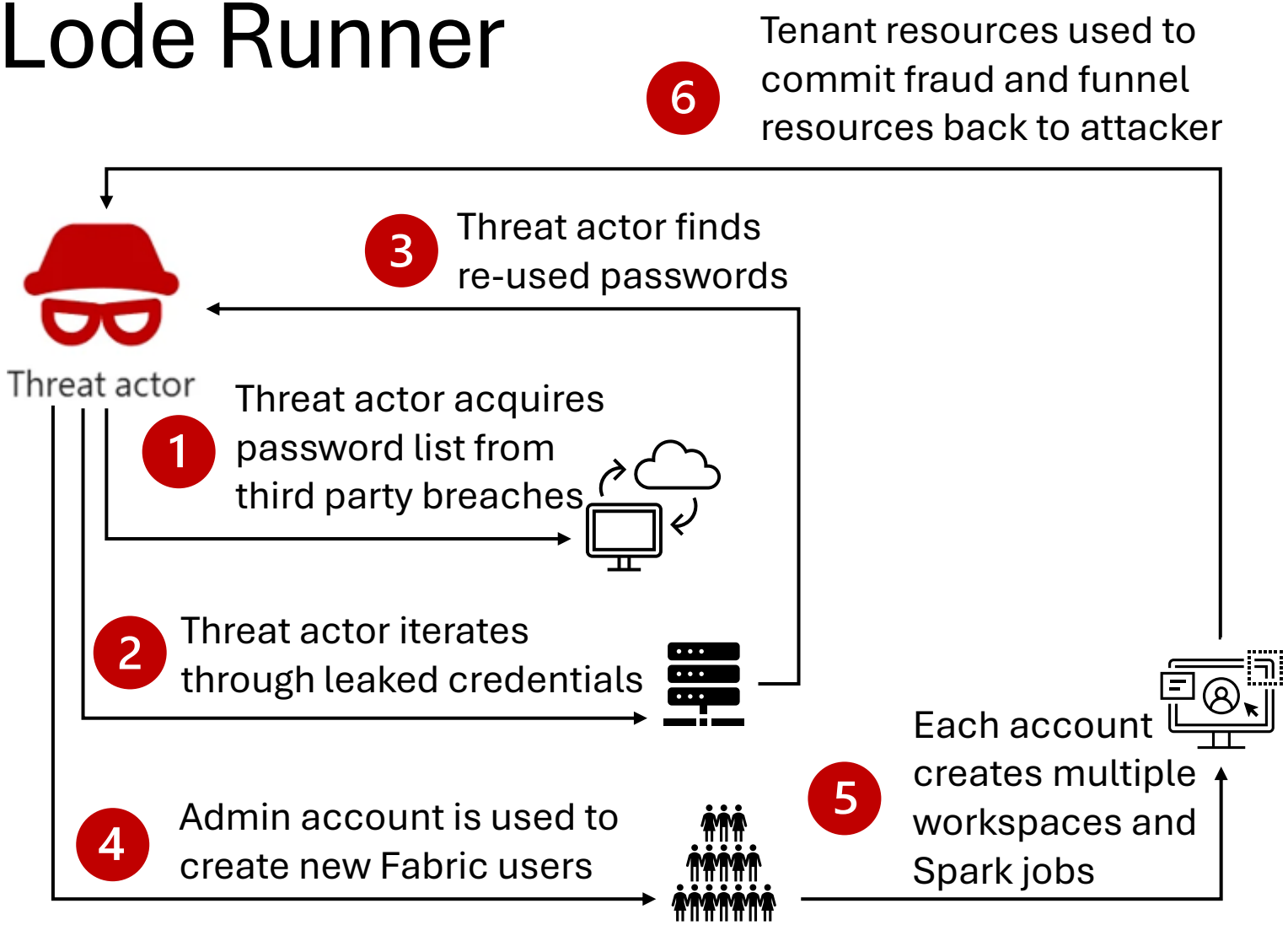
- Map known risks to adversarial Techniques, Tactics, and Procedures (TTPs) using a framework such as MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge)
- Deploy mitigations and countermeasures against these TTPs
- Ensure you are using the right controls and best practices to minimize the risks
- Our examples will all map to TTPs and best practices to mitigate. By following the best practices and guidance you can secure your Fabric workloads without having to be a security expert.



Real World Examples of Compromises



Lode Runner


6
Tenant resources used to commit fraud and funnel resources back to attacker
3
Threat actor finds re-used passwords
Threat actor
1
Threat actor acquires password list from third party breaches
2
Threat actor iterates through leaked credentials
5
Each account creates multiple workspaces and Spark jobs
4
Admin account is used to create new Fabric users



Lode Runner TTPs



Lode Runner Mitigations
Securing Credentials

- **Multifactor Authentication (MFA) Enforcement**
  EDU Tenant had no policy requiring MFA of any kind
- **Account use policies**
  Conditional access policies to enforce compliant devices and locations
- **Active Directory Configuration**
  Disable legacy authentication, which does not support MFA
- **User Access Reviews**
  Perform regular User Access Reviews (UAR) to ensure least privilege and access aligned to job function and business needs
- **User Training**
  Train users to only accept push notifications from acceptable MFA sources, to not re-use passwords, and to avoid phishing campaigns
- **Credential Stuffing**
  Enable account lockout policies to prevent brute forcing of password dump lists

Lode Runner Mitigations
Monitoring

- **Capacity**

  Enable monitoring and alerting on increases to quotas or capacities
- **Usage**

  Monitor for excessive use of cloud resources unaligned with business needs

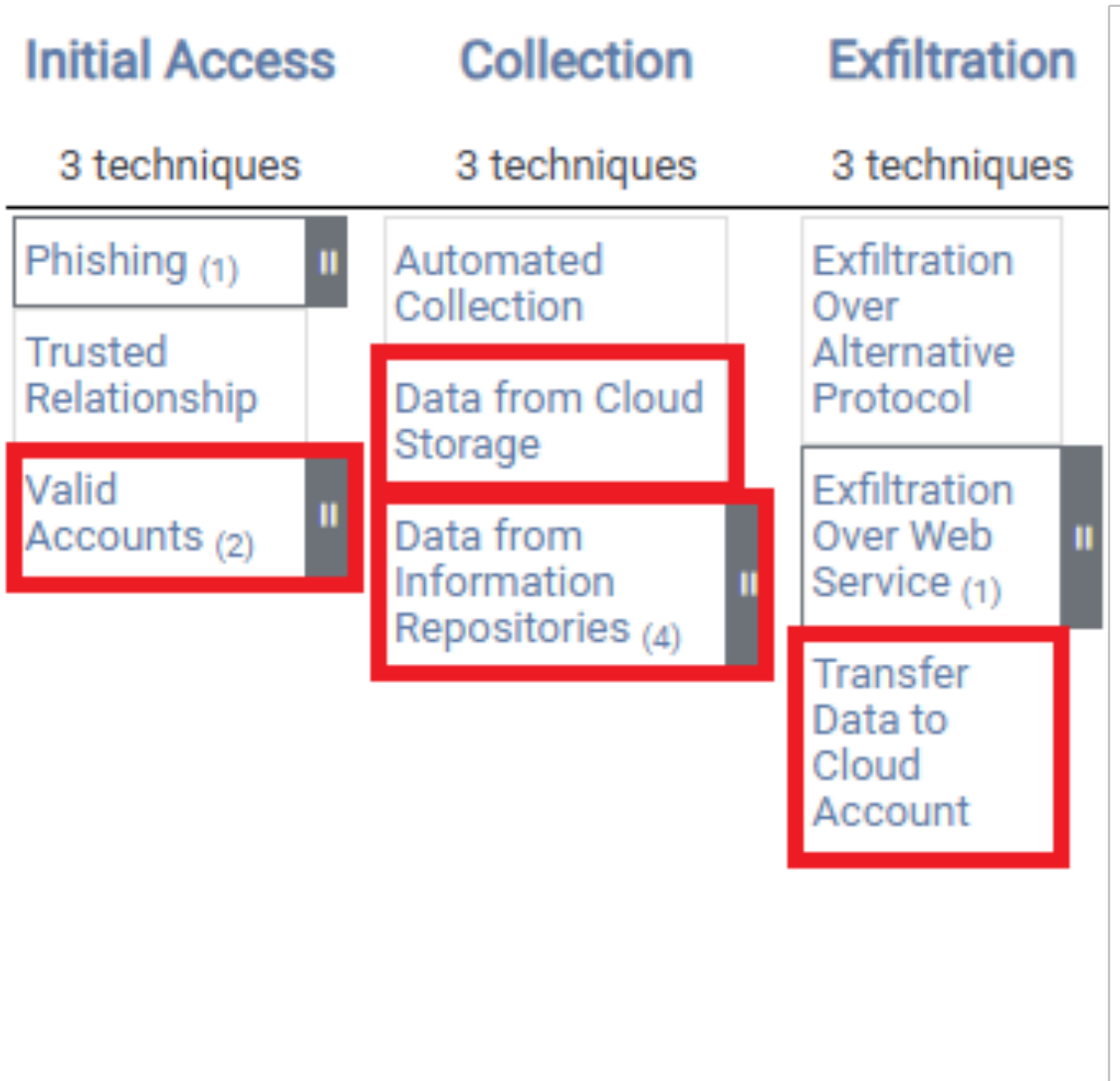
Broken Window

1. User creates misconfigured report with sensitive data in the semantic model
2. Threat actor creates custom scanner to find public reports with hidden tables and aggregated values
3. Threat actor iterates through discovered sites to find valuable sensitive data
4. Threat actor exfiltrates the data to an external store
5. Threat actor uses exposed data to cause reputational damage or financial gain

Threat actor

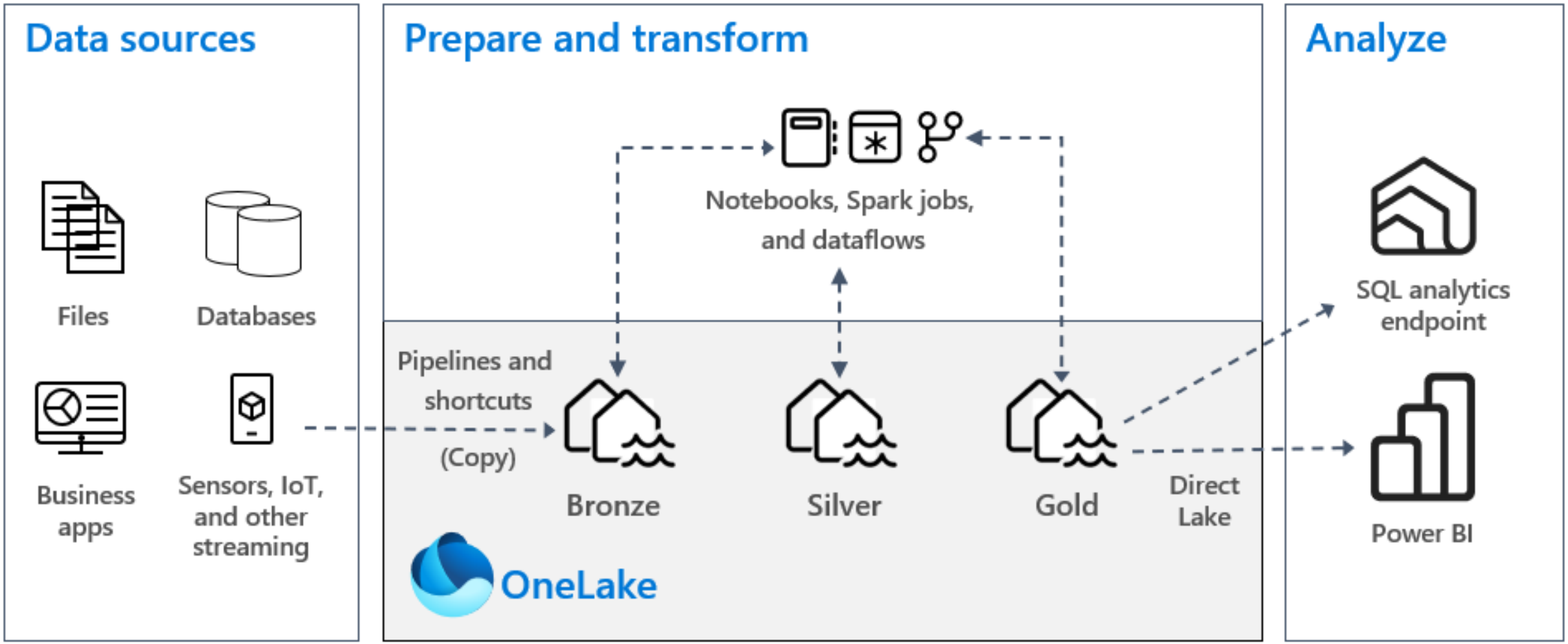


Broken Window TTPs



Broken Window Mitigations

Medallion Architecture



Broken Window Mitigations



Valid Accounts

User Access Reviews – Perform regular UARs to ensure least privilege and access aligned to job function and business needs.

Don't provide **access to raw data** of a sensitive nature, use a data source meant for reporting. Fabric is built to accommodate this model.



Data Collection

Limit the semantic model to only data that the report needs. Don't include sensitive data in the underlying model if you don't want it exposed.

Use a **Data Warehouse or Lakehouse as a "Gold Layer"** for reporting and Analysis. Use Fabric ETL (Extract, Transform, Load) and Transformation tools to ensure this data is safe for presentation at the data layer.



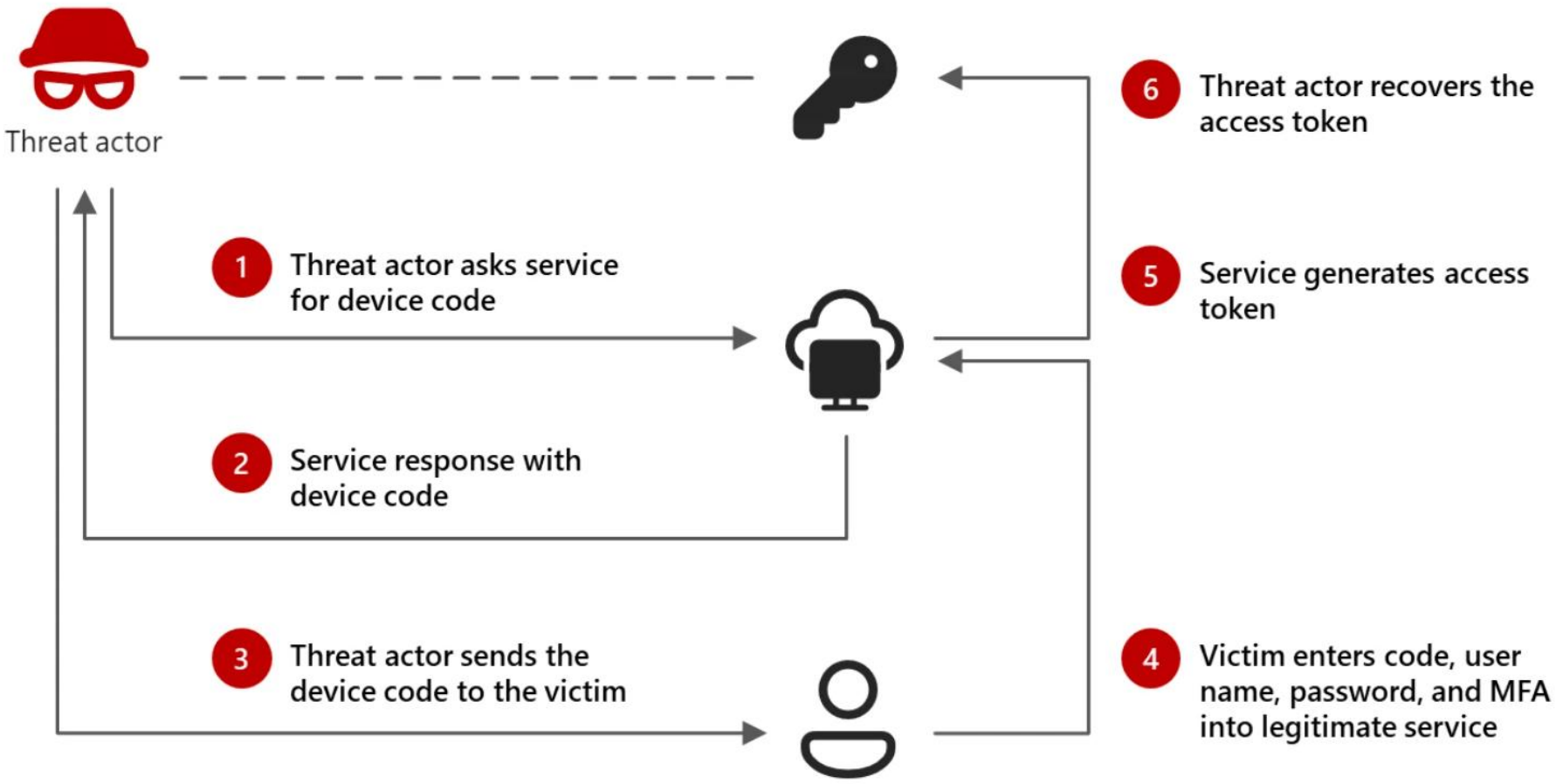
Data Exfiltration

Use **conditional access** and or **private links** to restrict inbound traffic

Use **labeling and DLP (Data Loss Prevention) policies** to protect the data

Perform **regular reviews** of the data in your Gold Layer to ensure it is safe and compliant for reporting and analysis

Storm-2372


Threat actor
1 Threat actor asks service for device code
2 Service response with device code
3 Threat actor sends the device code to the victim
4 Victim enters code, user name, password, and MFA into legitimate service
5 Service generates access token
6 Threat actor recovers the access token



Jan 30., Thu

Hello Mr. [redacted]

My name is [redacted], I am a researcher at the International Institute for Strategic Studies. From February 24 to 26, the Institute is holding a videoconference on the topic "The future of security in Europe." We invite you to take part in it.

Kind regards,

Associate Fellow for Conflict, Security and Development, IISS [redacted]

10:53

Jan 30., Thu

Nice to hear [redacted] nd you a registration link by email. After registration, I will send you all the necessary information about the video conference.

13:27

Jan 31., Fri

Dear [redacted], would it be convenient for you if I sent the link and details now?

12:14

Dear [redacted] I can register you now if it is convenient for you.

12:08

Perfect, thank you! Please, send the information / registration form to my official email address [redacted] (I need it there for the sake of transparency, as this is my private number) Thank you again!

12:11

I sent you a registration link and a Security ID for access. For security reasons, the ID is valid for 15 minutes, if you do not have time to enter it, I will send it again.

12:30

Microsoft Teams Need help?

Join the meeting

Meeting : **685 318 885 965**

ID:**CMUZKJSCW**

For organizers: Meeting options

Microsoft

Enter code to allow access

Once you enter the code displayed on your app or device, it will have access to your account.

Do not enter codes from sources you don't trust.

Code

Next

Storm-2372 Mitigations

- Only allow device code flow where necessary. Microsoft recommends blocking device code flow wherever possible. Where necessary, configure Microsoft Entra ID's device code flow in your Conditional Access policies.
- Educate users about common phishing techniques. Sign-in prompts should clearly identify the application being authenticated to.
- Leverage phishing-resistant authentication methods such as FIDO (Fast IDentity Online) Tokens, or Microsoft Authenticator with passkey. Avoid telephony-based MFA methods to avoid risks associated with SIM-jacking.
- Secure accounts with credential hygiene: practice the principle of least privilege and audit privileged account activity in your Entra ID environments to slow and stop attackers
- Use Entra Conditional Access to limit login locations to known IP ranges

Tenant Security Best Practices

- Conditional access policies in Entra to help mitigate against spear phishing and credential-based attacks. MFA, compliant devices, and network location-based logins all play a role.
- Privileged Identity Management (PIM) for Admin accounts
- Azure Service Principal (SPN) for Fabric Admin REST API operations *New in 2025*
- For sensitive environments consider using Private Links (workspace private links coming soon)



Workspace Security Best Practices

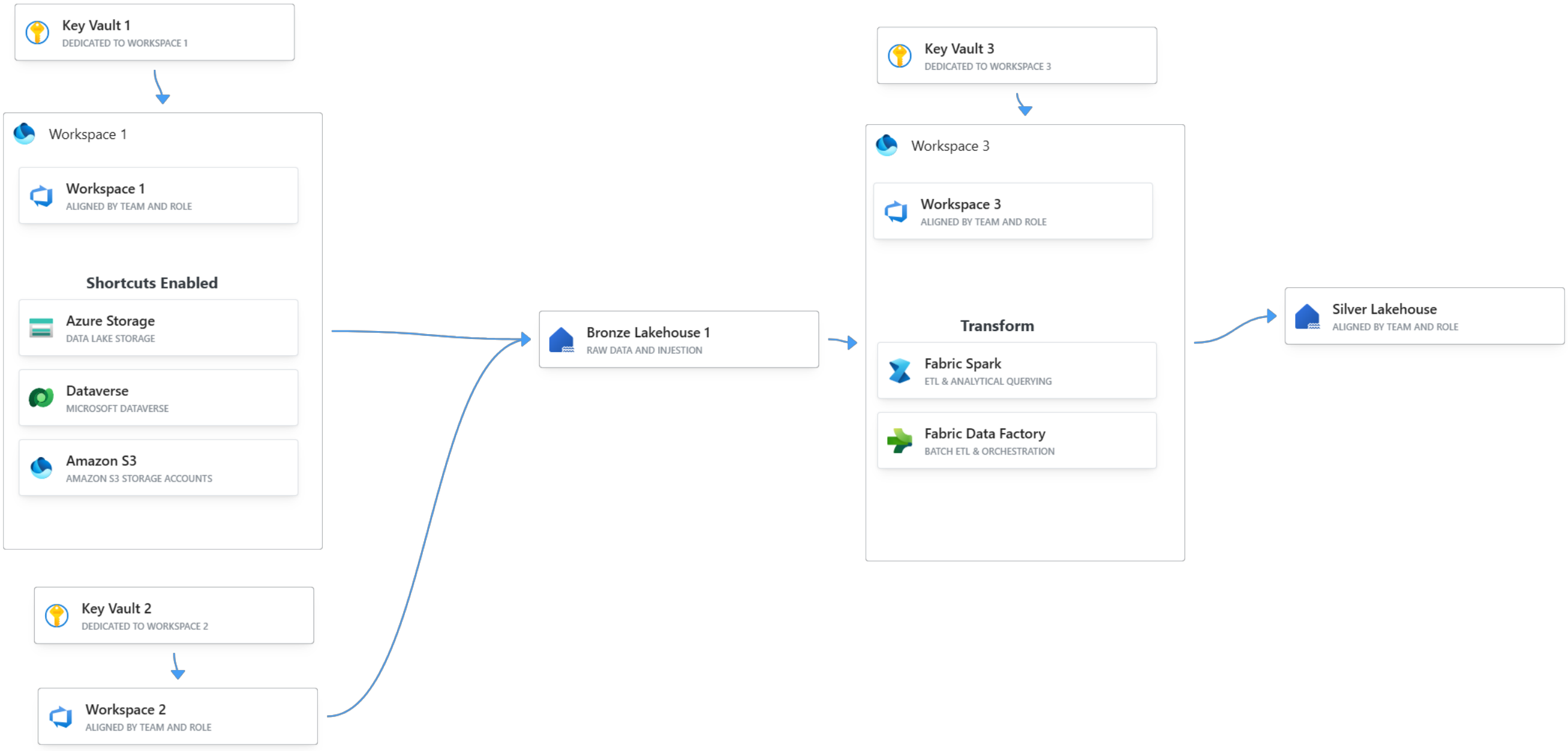
- Align workspaces to role, function, and business need
- When using a medallion architecture, don’t cross into the gold layer from Bronze and Silver in a single workspace
- Use granular permissions to only grant access to the artifacts needed by the user
- Try and keep the relationships between workspaces and Key Vaults tightly bound.



Workspace Tradeoffs

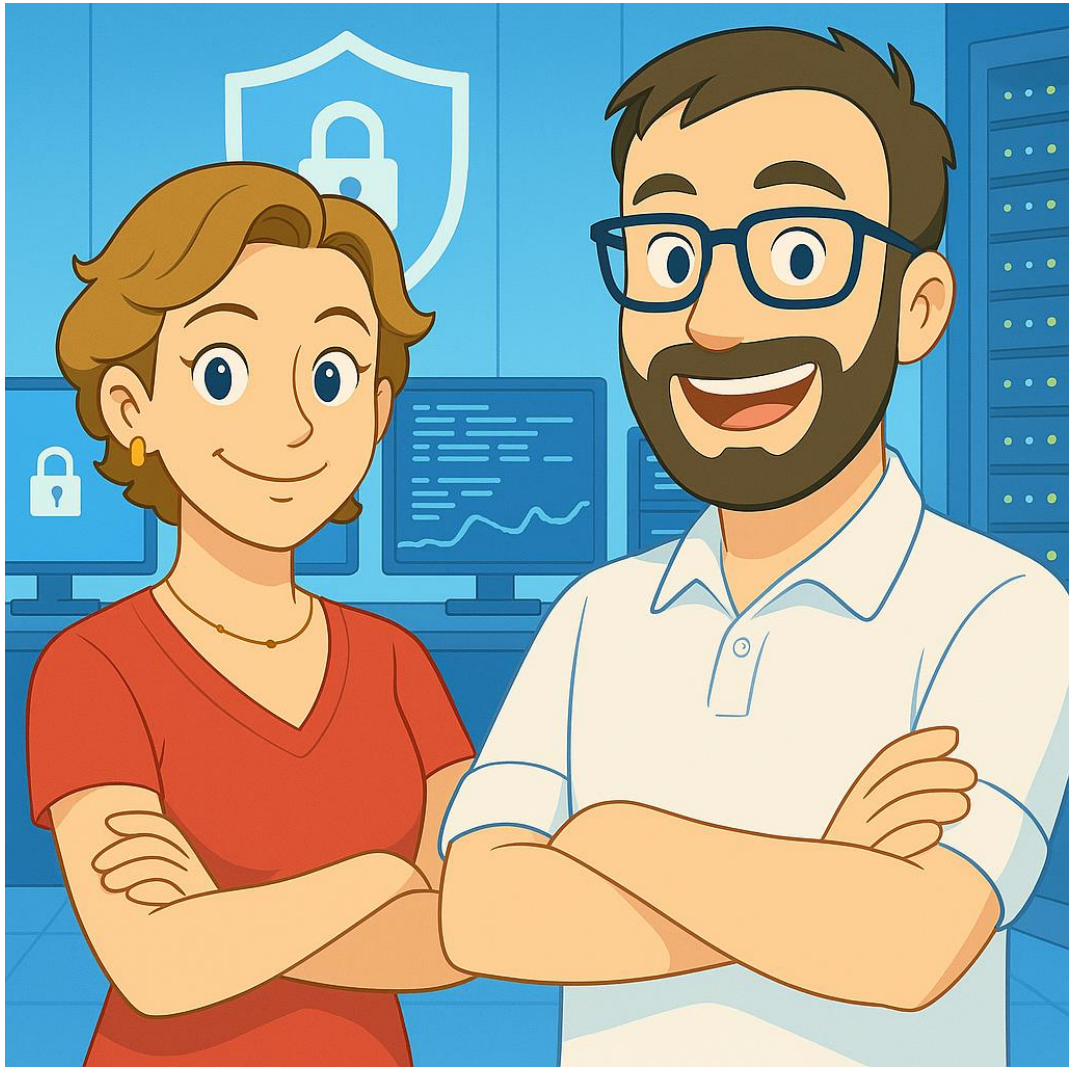
One workspace per Lakehouse	One workspace per team
Simple governance and maintenance. All data is in one workspace	Cleaner permissions model that aligns with org structure
One Lakehouse tied to a single Workspace, easy mental mapping	One Lakehouse tied to multiple Workspaces, need to understand the mapping and tables
Ease of administration, single workspace admin	Easier to scale security controls as more teams are added
Must use granular permissions per artifact	Multiple workspace admins means potential gaps in security posture between workspaces.
Workspace Identities must be used with additional controls around access	Workspace Identities can be used with little friction

Workspace Architecture



General Security Best Practices

- Regularly audit access of Apps, Service Principals, and Users to ensure least privilege
- Use built-in controls such as OneLake Security, Row Level Security (RLS), and Column Level Security (CLS) to limit access
- Use DLP (Data Loss Prevention) policies and Labeling to mitigate exfiltration risks
- Regularly monitor activity and usage and audit/alert on abnormal behavior
- Monitor for sensitive data exposure with a solution such as Microsoft Purview



Some of the other Security Sessions available

Topic	Time & Location	Speakers
Secure and Govern Your Data Estate with Microsoft Fabric and Purview	03/31 – 1:45pm @ Grand BR 119	Sunetra Virdi & Tony Themelis
A Database Designer's Favorite Security and Privacy Features in SQL Server/Azure DB	3/31 – 2:45pm @ Boulevard BR 162	Karen Lopez
Manage, Govern, and Secure Your Fabric Data with OneLake Catalog and Microsoft Purview	3/31 – 4:15pn @ Boulevard BR 160	Anton Fritz & Yaron Canar
Securing Your Data in Fabric: Best Practices for Data Warehouse Security in Microsoft Fabric	4/1 – 8:00am @ Premier BR 319	Dharini Sundaram & Freddie Santos
Securing Your Data with OneLake in Fabric: Adoption, Security, and Disaster Recovery	4/1 – 8:00am @ Premier BR 310	Nandhini Ellappan & Sarvesh Raghupathy
Securing Your Fabric Workloads – Best Practices from the Fabric Security Team	**4/1 – 9:15am @ Boulevard BR 162**	**Elena Scilletta & Paddy Osborne**
Securing Fabric Copilot Interactions: Introducing Purview Controls	4/1 – 1:45pm @ Grand BR 116	Betsy Linares & Shilpa Ranganathan
Network Security for SaaS Platform	4/1 – 3:15pm @ Grand BR 119	Arthi Ramasubramanian Iyer & Rick Xu
Secure & Govern your Data Estate with Microsoft Purview (Keynote)	4/2 – 8am @ Grand BR 116, 119	Maithili Dandige
Deep Dive on OneLake Data Security	4/2 – 10am @ Premier BR 313	Aaron Merrill & Cristian Petculescu
Microsoft Purview Data Security in the Era of AI	4/2 – 10am @ Grand BR 120	Joanne Marone & Maithili Dandige
Securing Your SQL database in Fabric is as Easy as 1-2-3	4/2 – 10am @ Grand BR 121	Jakub Szymaszek
Zero Trust in Action: Key Azure Security Principles	4/2 – 4:30pm @ Grand BR 113	Deepthi Goguri

Resources

- Fabric Security - http://aka.ms/MSFabricSecurity
- MITRE ATT&CK diagram - https://attack.mitre.org
- MFA Authentication - https://learn.microsoft.com/en-us/entra/identity/authentication/concept-mfa-howitworks
- Workspaces RBAC - https://learn.microsoft.com/en-us/fabric/fundamentals/roles-workspaces
- Capacity Monitoring - https://learn.microsoft.com/en-us/fabric/admin/service-admin-premium-capacity-notifications
- PIM - https://www.linkedin.com/pulse/azure-ad-privileged-identity-management-power-bi-why-rui-romano/
- SPN for Admin APIs - https://blog.fabric.microsoft.com/en/blog/admin-api-updates-and-upcoming-definition-changes
- DPL policies - https://learn.microsoft.com/en-us/purview/dlp-powerbi-get-started
- MIP - https://learn.microsoft.com/en-us/information-protection/develop/setup-configure-mip
- Audit Logs Operations - https://learn.microsoft.com/en-us/fabric/admin/operation-list
- Medallion Architecture - https://learn.microsoft.com/en-us/fabric/onelake/onelake-medallion-lakehouse-architecture

Thank you!

Q&A